BURP WORKBENCH KR

0.23.0 실전 점검 가이드

커뮤니티 보안 실습 사이트 3.5.0과 함께 사용하는 한국어 안내서

대상을 정하고, 여러 계정의 권한을 비교하고, 발견 근거를 보관하는 전체 흐름을 설명합니다. 한 가지 탐지 결과보다 '어떤 조건에서 무엇을 확인했는가'를 남기는 데 초점을 맞춥니다.

이 안내서의 기준	내용
확장	Burp Workbench KR 0.23.0
실습 사이트	LOOP Community Security Lab 3.5.0
준비물	Burp Suite, 확장 JAR, Docker 실행 환경 또는 개발 테스트 환경
권장 순서	설치 → SCOPE → 계정·업무 → 비교·탐색 → 증거 → 재검토
화면의 성격	운영 Swing 코드를 헤드리스 렌더한 미리보기, 예시 데이터
검증 근거	해당 버전 PR과 docs/VERIFICATION_0.23.0.json

그림은 실제 확장 UI 구성 요소를 사용했지만 Burp를 직접 조작한 캡처는 아닙니다. 이 안내서의 예시 화면이나 예상 결과를 실제 취약점 검증 완료로 해석하지 마세요.

2026-10-11 · GitHub 버전별 배포 안내

01 · 전체 점검 지도

처음에는 정상 기능을 사용해 기준 요청을 확보합니다. 이후 동일한 리소스·동일한 입력에 대해 계정 또는 한 가지 조건만 바꾸어 비교합니다.

단계	도구	남길 결과
1. 범위	트래픽, SCOPE 목록	허용 Origin·경로
2. 기준	활동 추적, 계정별 점검	계정·역할·API·입력 목록
3. 탐색	JS 추출, 환경 탐색, URL 수집	후보와 출처, 미점검 대상
4. 비교	권한 비교, 페이로드, 데이터 도구	정상·변경·대조 요청과 판정 근거
5. 연결	응답 분석, 업무 흐름	원본 요청, 쓰기·조회 단계
6. 마감	증거 묶음, 업무별 현황	저장한 ZIP, 수동 완료, 재검토 이유

하루의 효율적인 진행 순서

1. SCOPE를 등록하고 Alice·Bob·Admin의 로그인 상태를 확인합니다.
2. 게시글 읽기, 수정, 댓글, 첨부, 쪽지를 각각 정상 사용합니다.
3. 활동 추적에서 미점검 계정×API 조합을 골라 작은 업무로 묶습니다.
4. 권한 비교와 대조 요청으로 한 가지 가설씩 확인합니다.
5. 근거를 ZIP으로 저장한 뒤 계정별 입력과 URL을 수동 완료합니다.
6. 역할·중요 입력·대상이 바뀌면 재검토 목록부터 다시 확인합니다.

수집 수, 검사 실행 수, 수동 완료 수, 저장한 증거 수는 서로 다릅니다. 관측만 된 API를 '점검 완료'로 처리하지 않습니다.

02 · 다운로드와 설치

저장소의 downloads/README.md에서 같은 버전의 파일을 고릅니다. GitHub 파일 화면에서 Raw 또는 다운로드 버튼으로 실제 파일을 저장하세요.

필요한 파일	위치
Burp에 넣을 확장	downloads/extensions/0.23.0/ 의 .jar
수정·독립 빌드할 소스	같은 폴더의 source ZIP
실습 사이트 실행 묶음	downloads/docker/3.5.0/ 의 ZIP
현재 그림 안내서	downloads/guides/0.23.0/ 의 PDF

1. 기존 Workbench가 로드되어 있으면 해제하고 최신 JAR 하나만 로드합니다.

2. Burp의 Extensions 화면에서 Java 확장을 추가하고 JAR를 선택합니다. 메뉴 이름은 Burp 버전에 따라 다를 수 있습니다.

3. Workbench KR 탭과 Extensions의 오류 출력을 확인합니다.

4. Docker ZIP을 풀고 동봉한 README 및 실행 스크립트를 확인합니다.

5. 사이트와 Burp 브라우저가 준비되면 127.0.0.1:8088만 먼저 사용합니다.

```
docker compose up -d --build --wait --wait-timeout 900
docker compose ps
docker compose logs --tail=100
docker compose down
```

Docker ZIP은 소스와 실행 설정을 묶은 파일입니다. Docker 설치 프로그램이나 사전 빌드 이미지가 아니며 첫 빌드에는 이미지·Maven 의존성 다운로드가 필요합니다. DB 볼륨을 지우는 down -v는 실습 데이터를 삭제하므로 초기화할 때만 사용합니다.

03 · 트래픽과 SCOPE

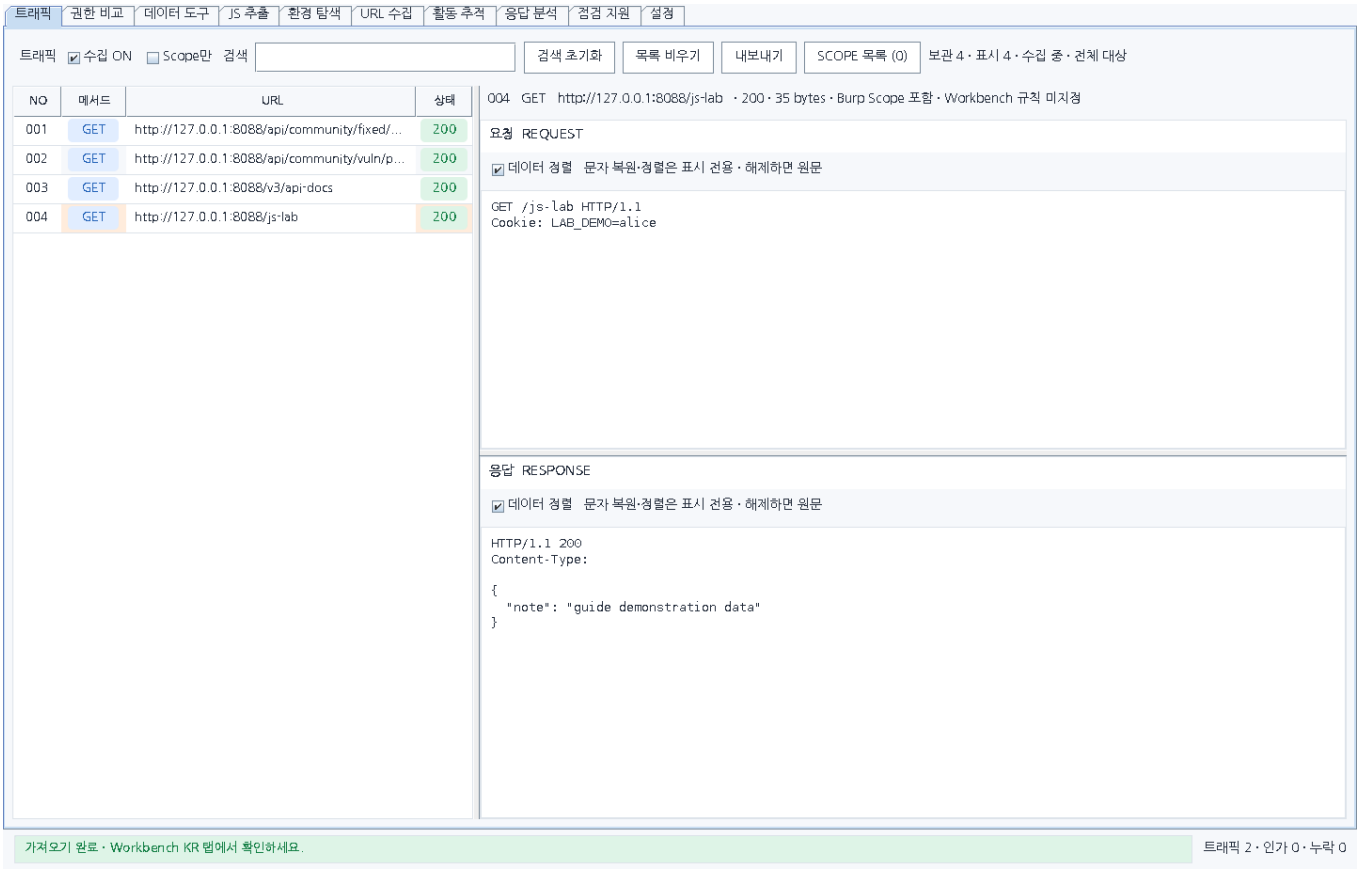


그림 01. 트래픽 도구의 실제 Swing 미리보기. 예시 요청을 사용했습니다.

1. Burp 브라우저에서 로컬 사이트를 사용해 응답이 있는 요청을 수집합니다.

2. 요청을 우클릭해 SCOPE 지정 → 선택 URL 경로 추가 또는 선택 도메인 전체 추가를 실행합니다.

3. SCOPE 목록에서 프로토콜·호스트·포트와 경로 포함 관계를 확인합니다.

4. 수집 범위를 좁히려면 ‘Scope만’을 켭니다. 기존 History는 우클릭으로 가져옵니다.

Workbench SCOPE와 Burp Target Scope는 별도로 관리됩니다. 127.0.0.1:8088과 localhost:8088, 다른 포트는 같은 Origin이 아닙니다. 권한 비교·환경 탐색의 대상이 제외되면 먼저 목록의 정확한 주소를 확인하세요.

트래픽은 제한된 최근 목록입니다. 중요한 패킷은 증거로 옮기고, 민감한 실제 세션을 안내서 예시와 섞지 않습니다.

04 · 활동 추적으로 누락 찾기

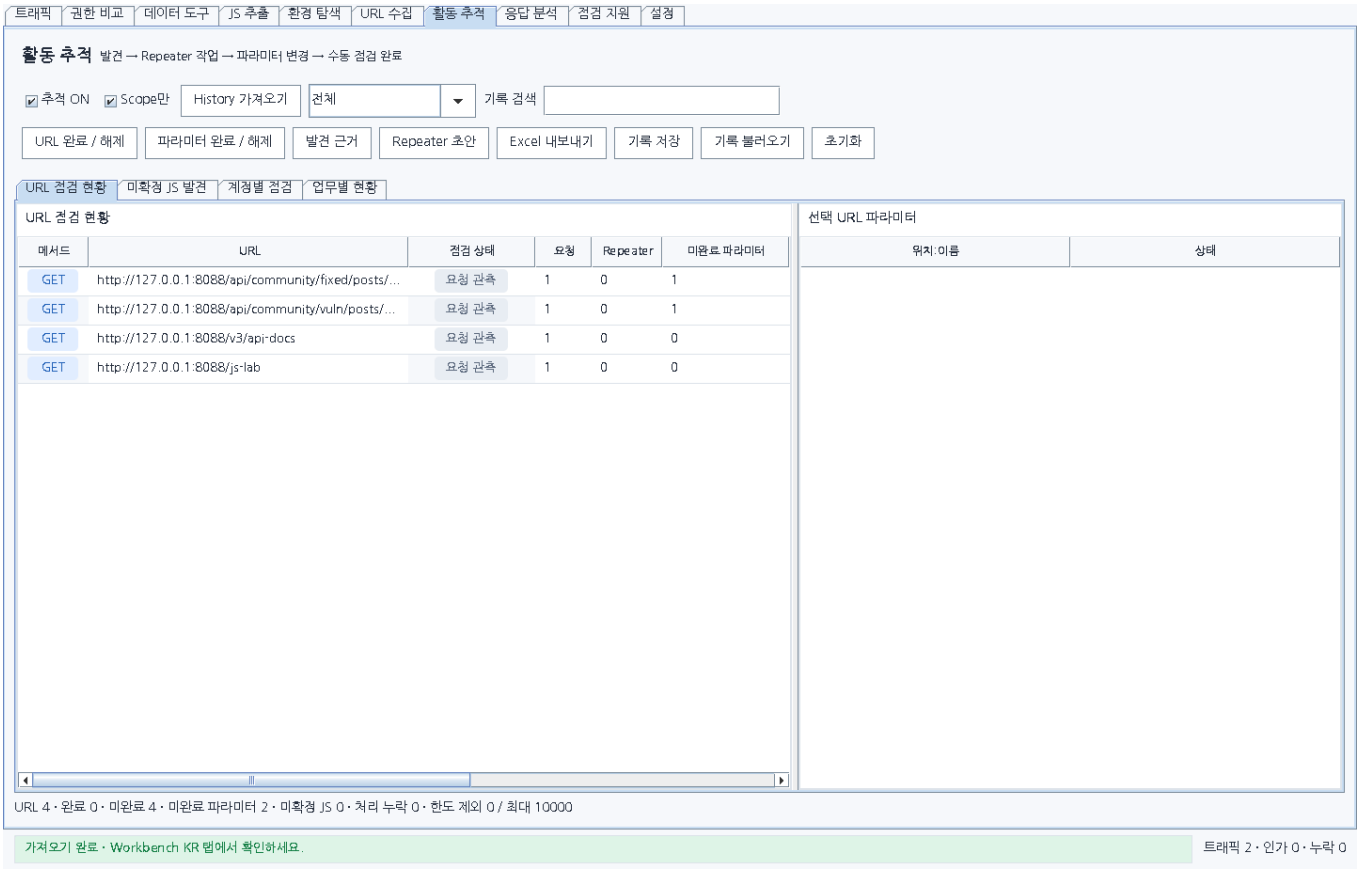


그림 02. 활동 추적. URL 발견과 점검 완료는 별도 상태입니다.

활동 추적은 메서드·URL·입력 이름과 출처를 모읍니다. JS에서 찾은 후보, 실제 트래픽, 검사 실행 기록을 한곳에서 비교합니다.

1. 목록에서 미점검 또는 재검토가 필요한 대상을 고릅니다.

2. URL 입력, 본문 입력, 헤더, 쿠키, 숫자·UUID 경로 후보를 확인합니다.

3. 출처가 JS라면 소스 위치로 이동해 실제 호출 조건과 인증 여부를 확인합니다.

4. 검사 후 입력과 URL을 수동 완료합니다. 실제 응답을 보지 않은 후보는 미점검으로 유지합니다.

숫자 경로를 찾았다는 사실이 소유자 관계나 IDOR를 증명하지는 않습니다. GET과 POST도 별도의 점검 대상입니다. JSON은 재개용 메타데이터이며 실제 로그인 상태를 복원하지 않습니다.

05 · 계정별 점검 준비

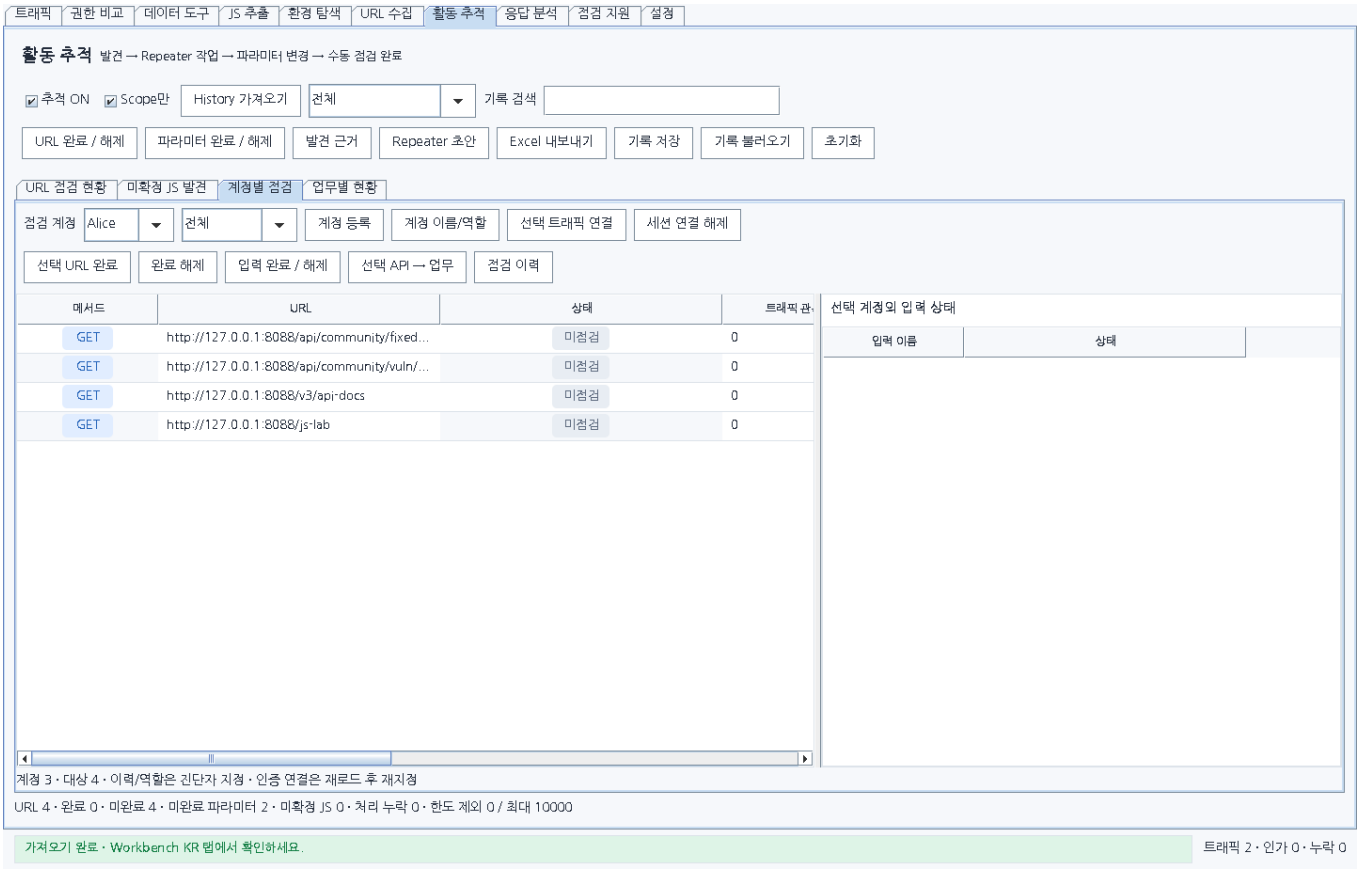


그림 03. 계정별 점검의 예시 계정과 대상. 미점검 상태를 그대로 표시합니다.

1. 활동 추적 → 계정별 점검 → 계정 등록에서 이름·Origin·역할·조직을 입력합니다.

2. 현재 브라우저의 실제 로그인 계정을 확인합니다.

3. 선택 트래픽 연결 또는 권한 비교의 '점검 이력 계정'으로 세션을 명시적으로 연결합니다.

4. Alice·Bob·Admin을 각각 연결하고 인증 조건이 중복되지 않는지 확인합니다.

계정 이름과 역할은 진단자가 선언한 정보입니다. 같은 세션 값으로 서버 측 신원이 바뀌는 상황을 자동으로 증명하지 않습니다. 재로드 후에는 인증 연결을 다시 지정해야 합니다.

한 계정의 완료는 다른 계정의 완료가 아닙니다. 역할·조직을 바꾸면 관련 완료가 재검토로 전환되며, 단순 이름 변경은 완료를 유지합니다.

06 · 업무 완료 조건을 정하기

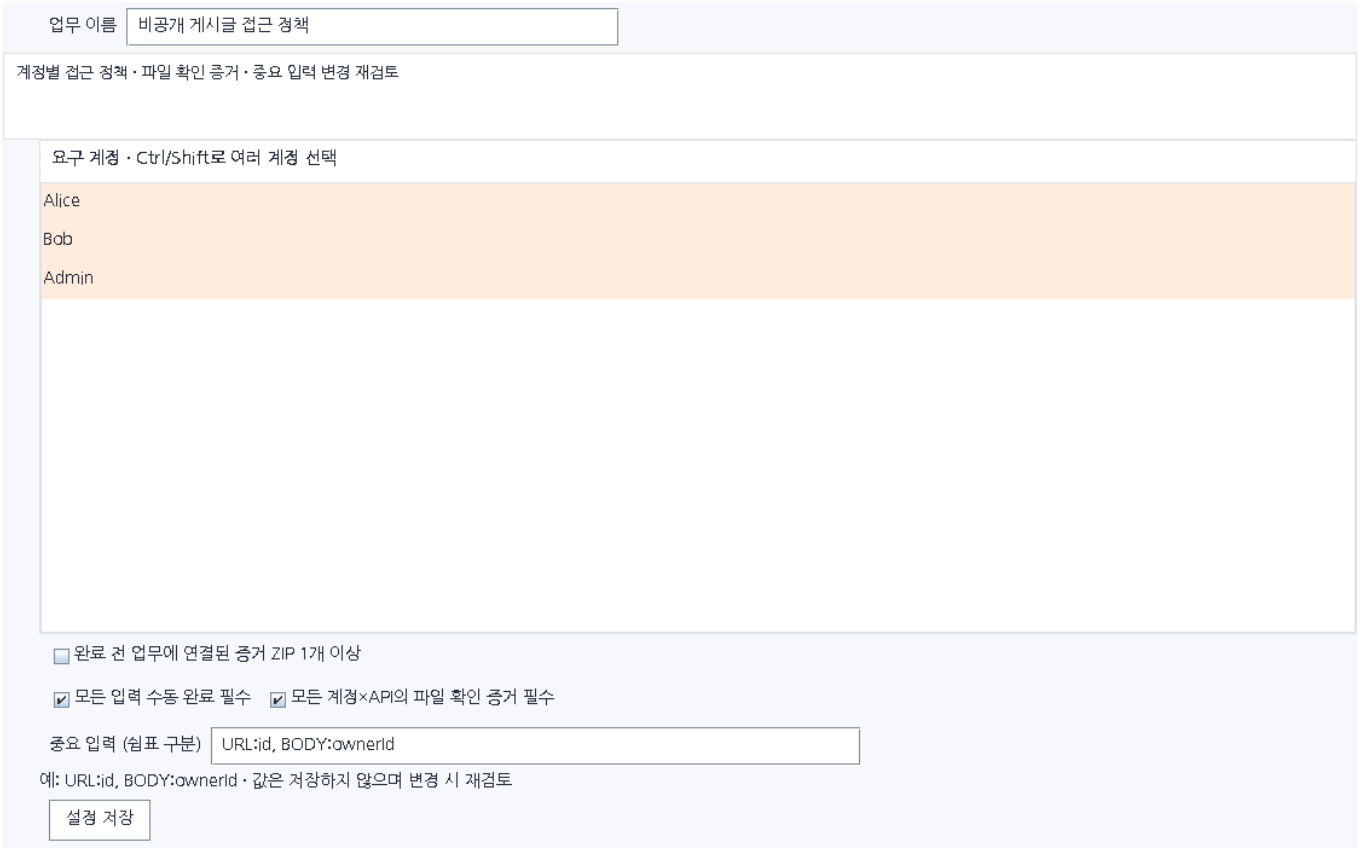


그림 04. 업무 설정의 엄격 입력·증거 조건. 헤드리스 UI 미리보기입니다.

업무 등록 후 필요한 계정과 API를 연결합니다. 같은 Origin의 계정×API 조합만 요구 대상으로 계산합니다.

조건	의미
모든 입력 수동 완료 필수	관측한 입력별 검토를 끝내야 업무 마감 가능
모든 계정×API의 파일 확인 증거 필수	각 요구 조합에 SHA-256 확인된 파일 근거 필요
중요 입력	URL:id, BODY:ownerId처럼 값 변경 시 재검토할 이름

중요 입력을 정한 뒤 정상 요청을 한 번 관측해 기준을 잡습니다. 값은 내보내지 않고 메모리 해시만 비교하므로 재시작 뒤에는 기준을 다시 확인합니다. 페이지 번호처럼 자주 바뀌는 입력까지 중요 입력으로 넣으면 불필요한 재검토가 늘어납니다.

07 · 권한 비교의 기준

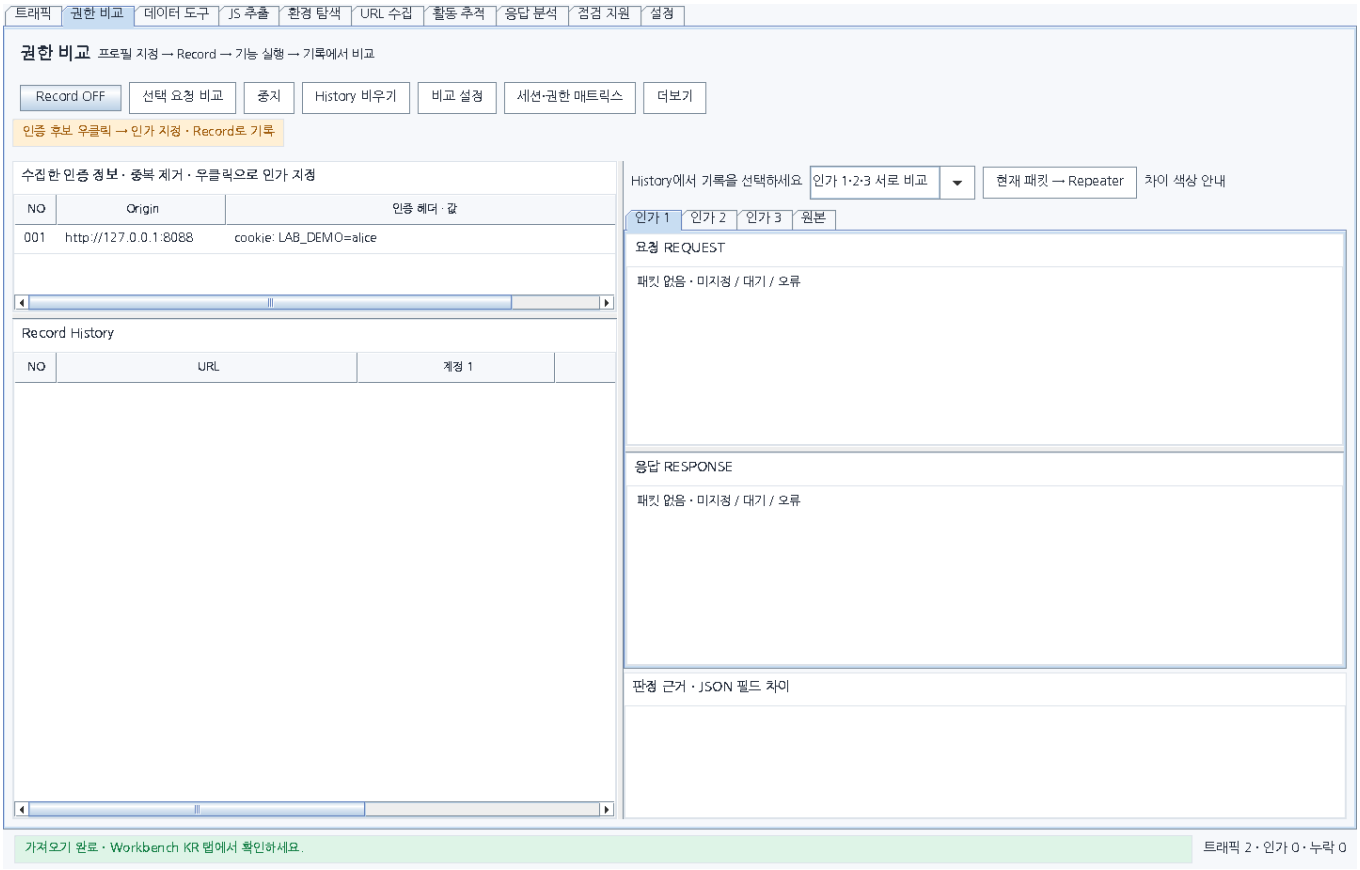


그림 05. 권한 비교 패널. 계정 세션과 기대 정책을 먼저 확인합니다.

1. Bob 소유의 비공개 글처럼 소유 관계가 명확한 정상 요청을 선택합니다.

2. Alice·Bob·Admin 세션과 비로그인 대조군을 준비합니다.

3. 매트릭스에서 기대 정책을 ALLOW 또는 DENY로 명시합니다.

4. 비교를 실행하고 실제 전송 요청·HTTP 상태·소유 JSON 경로·본문 근거를 함께 읽습니다.

200이라는 숫자만으로 읽기 성공을 단정하지 마세요. 오류 JSON을 200으로 돌려주는 경우도 있고 404가 실제 미존재인지 권한 차단인지 구분해야 합니다.

DENY의 404/410은 동일 대상·인증의 소유자 재조회가 2xx이고 본문이 일치해야 차단 근거를 유지합니다. ALLOW인데 404/410이면 재조회 근거가 있어도 정책·세션을 재검토합니다. 인증이 동일한 비교는 교차 계정 검증으로 보지 않습니다.

08 · 커뮤니티 실습 한 바퀴

실습 계정은 alice, bob, moderator, admin이며 기본 비밀번호는 LabOnly!2026입니다. 모두 로컬 가짜 계정입니다. 로그인 후 사이트의 취약 구현과 수정 구현을 오가며 같은 기능을 비교합니다.

가설	기준·대조	확인할 근거
비공개 글 IDOR	Bob의 글 102를 Alice로 조회	본문 소유자·내용, Bob 재조회
첨부파일 접근 통제	허용 계정과 타 회원 다운로드	전체/일부 응답, 길이·해시
관리자 권한 상승	일반 세션과 실제 Admin	role 입력값과 서버 신원 구분
저장형 출력	댓글 또는 업로드에 고유 마커	쓰기→목록→상세→원문 단계
검색 입력	정상 문자열과 단일 변경 입력	오류·결과 차이, 같은 조건 재현
숨은 파라미터	lab_hidden 유무	취약·수정 경로의 반영 차이

```
GET /api/community/fixed/posts/102
GET /api/community/vuln/posts/102
```

예상 정책은 fixed에서 Bob과 Admin의 읽기 허용, Alice의 읽기 차단입니다. 계정·데이터가 초기화되었는지 확인하고 현재 응답으로 판단하세요. 예제 번호 자체를 실제 검증 결과로 기록하지 않습니다.

보고서 하나에는 하나의 영향과 최소 재현 절차를 담습니다. 정상 소유자 요청, 비허용 계정 요청, 수정 경로 대조를 함께 남기면 불필요한 반복과 오판정을 줄일 수 있습니다.

3.5의 추가 기능: /bounty-lab

시나리오	실제 경로·입력	고를 대조
정책 다양성	/api/bounty/{mode}/objects/{id}	201 공개, 202 Bob, 203 조직 A, 204 공유, 205 조직 B, 206 Alice
저장·조회	POST /api/bounty/{mode}/stored, form value	응답 url을 GET: 취약 HTML / 수정 문자 출력
업로드·다운로드	POST /api/bounty/{mode}/uploads, 쿼리 name=probe.html	취약 text/html / 수정 .txt·attachment

{mode}는 vuln 또는 fixed입니다. 수정 쓰기와 POST /api/bounty/reset에는 X-CSRF-Token이 필요합니다. reset은 현재 계정의 새 실습 데이터만 정리합니다. 자세한 정책은 /api/bounty/manifest를 확인하세요.

09 · JS에서 API 후보 찾기

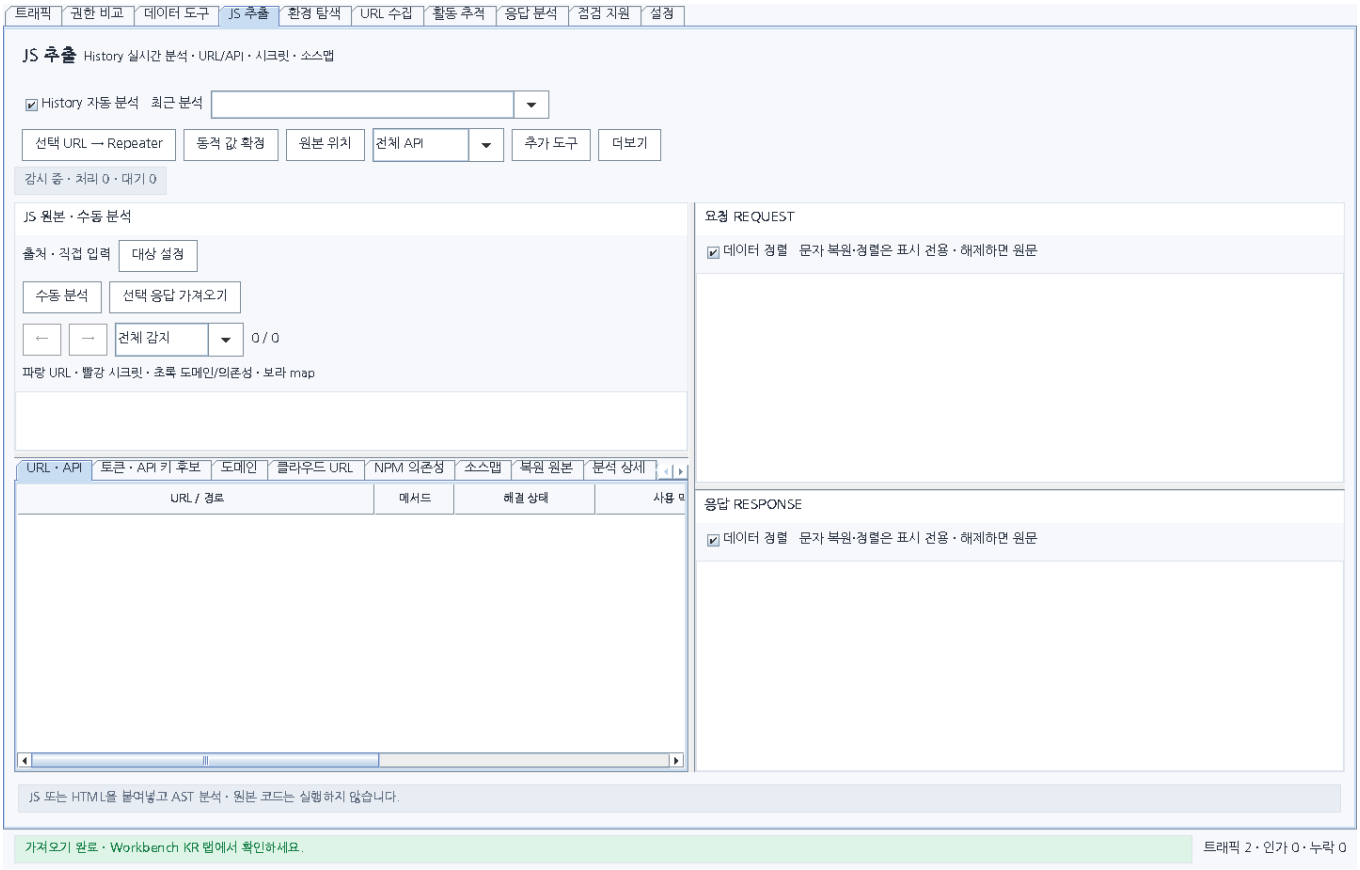


그림 06. JS 추출. 수집 상태와 분석 출처를 함께 확인합니다.

1. /js-lab을 방문하고 실제 JS 응답을 확보합니다.

2. SCOPE에서 대상을 선택해 분석하고 요청 메서드·URL·파라미터 이름을 확인합니다.

3. 조합이 확정되지 않은 API는 미확정 후보로 보관합니다.

4. 소스 위치에서 호출 조건과 변수 값을 확인한 뒤에만 실제 대상을 확정합니다.

5. 확인한 후보를 활동 추적과 연결하고 미점검 대상을 줄입니다.

문자열이나 소스맵에서 찾은 URL은 서버 기능 존재나 접근 성공의 증거가 아닙니다. 번들에 남은 오래된 경로, 조건부 코드, 동적 값이 있을 수 있습니다. 대기열·처리 제외 상태를 확인하고 큰 수집은 여러 묶음으로 나누세요.

10 · 환경 탐색

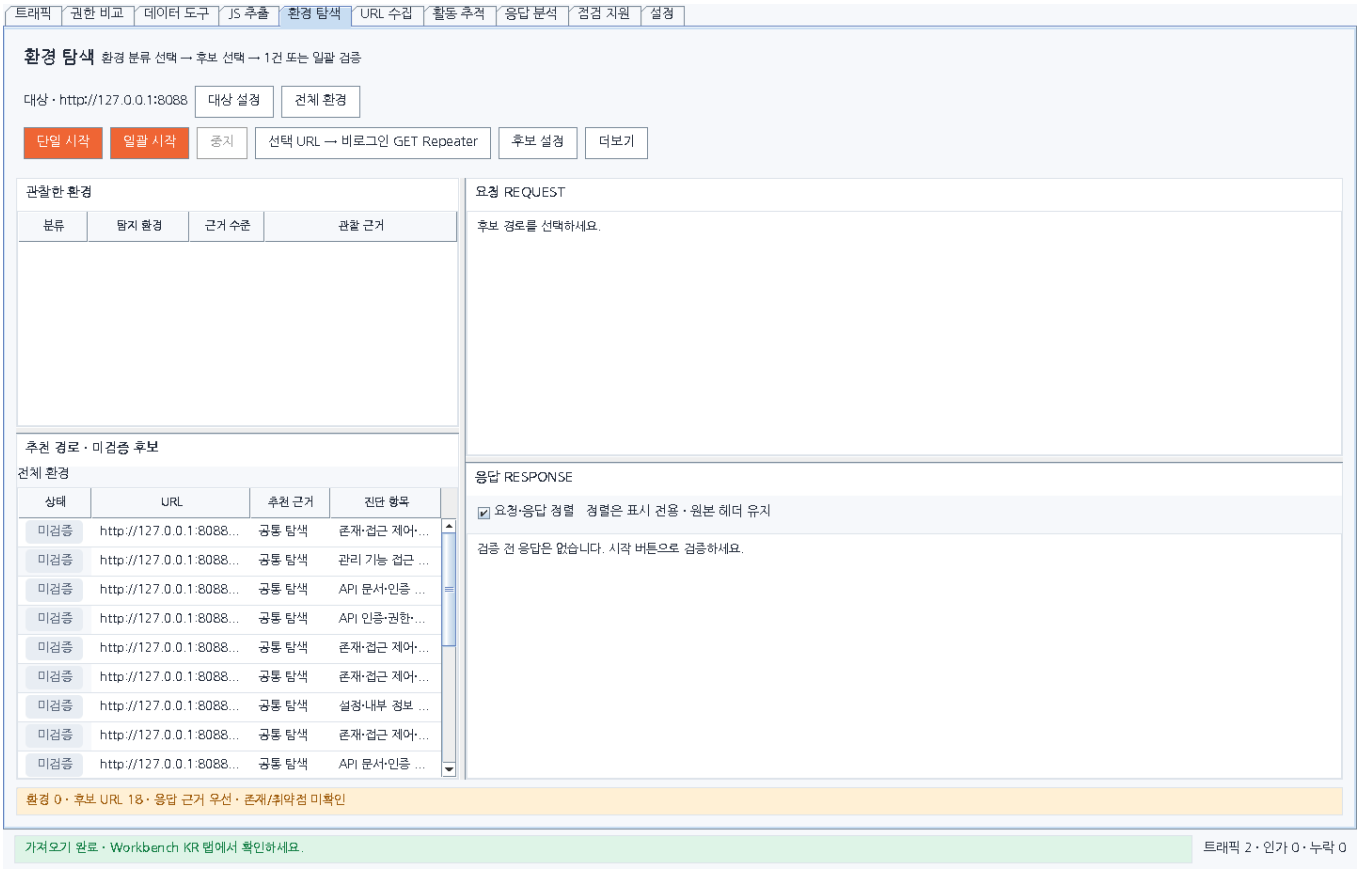


그림 07. 환경 탐색. 명시적으로 선택한 계정과 대상을 사용합니다.

서버·프레임워크·응답 헤더·발견 경로를 점검 계획으로 연결하는 도구입니다. 후보의 존재와 보안 영향을 구분합니다.

1. 대상 설정에서 SCOPE 내 Origin과 탐색 범위를 고릅니다.

2. 인증이 필요하면 권한 비교에서 준비한 계정을 명시적으로 선택합니다.

3. 관측된 기술·응답을 읽고 영향 있는 경로만 후속 대상으로 선택합니다.

4. 필요한 항목을 Repeater와 활동 추적으로 옮깁니다.

일반 계정에서 나온 응답과 관리자 응답을 섞으면 접근 범위를 과대평가할 수 있습니다. 호스트·포트·세션이 달라질 때마다 기준을 다시 확인하세요. 실패·제외 결과도 '기능 없음'으로 단정하지 말고 타임아웃과 SCOPE 상태를 확인합니다.

11 · URL 수집과 후보 정리

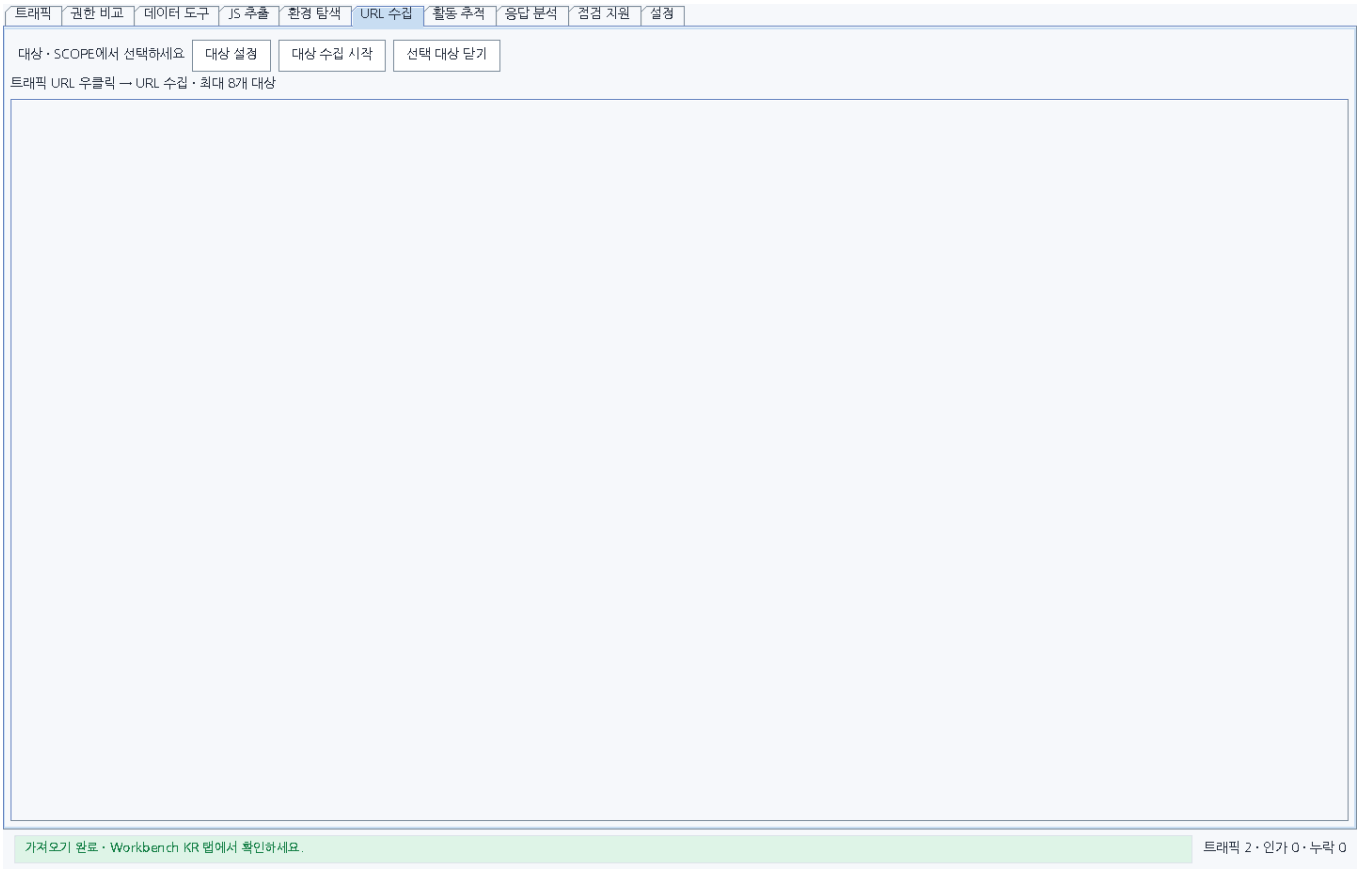


그림 08. URL 수집. 발견 메서드와 출처를 보존합니다.

URL 수집은 여러 출처의 경로를 점검 목록으로 만드는 단계입니다. 수집된 URL은 실행된 요청이나 취약점과 동일하지 않습니다.

1. 대상 설정에서 등록한 SCOPE를 선택합니다.

2. 후보의 메서드, 경로, 출처를 읽습니다.

3. 같은 경로라도 인증 정책이나 메서드가 다르면 각각 검토합니다.

4. 후보를 활동 추적에 연결하고 실제 요청에서 상태를 확인합니다.

5. GET 검증 후 '선택 검증 원본 → 증거'로 실제 요청·응답을 전달합니다.

중복이 많은 목록은 공개·회원·소유자·관리자 기능으로 나누세요. 상태·메서드·정책이 다른 대표 요청을 확인합니다. 계정을 지정하지 않은 GET도 Burp 세션 규칙의 영향을 받을 수 있으므로 '비로그인' 성공으로 단정하지 않습니다.

12 · Passive와 원본 요청

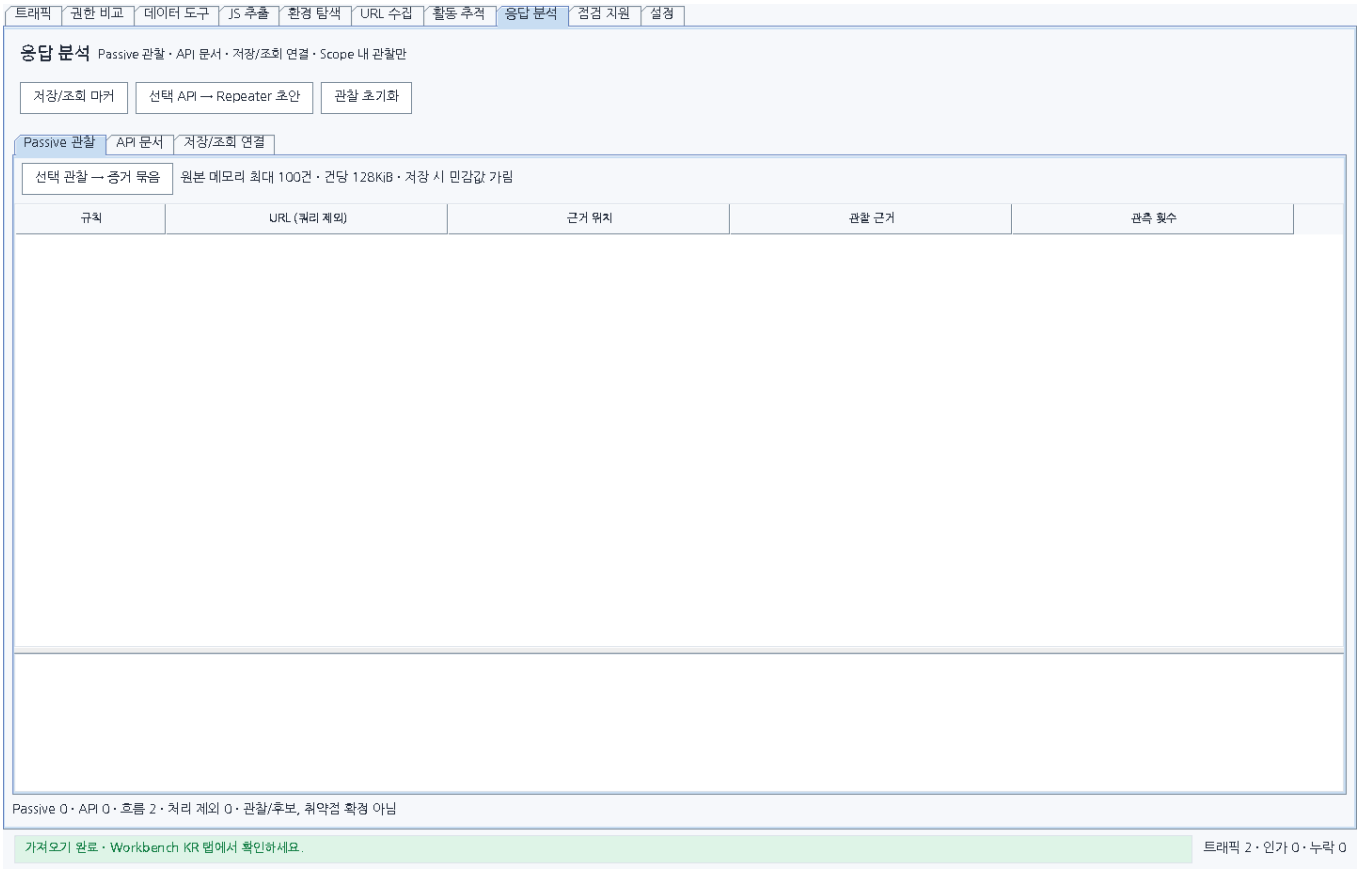


그림 09. 응답 분석. 관찰 결과를 실제 원본과 연결해 검토합니다.

응답 분석은 SCOPE 내에서 관측된 패킷을 바탕으로 오류 노출·헤더·API 문서·저장 흐름을 확인합니다. 자동 추가 요청이나 자동 취약점 확정 단계가 아닙니다.

1. 발견 행을 선택해 규칙, 위치, 근거와 영향 URL을 확인합니다.

2. 원본 패킷 연결을 이용해 실제 메서드·상태·응답 내용을 확인합니다.

3. '선택 관찰 → 증거 묶음'으로 현재 대표 원본을 보냅니다. 그룹의 다른 영향 URL까지 입증되는 것은 아닙니다.

4. OpenAPI의 경로 변수는 직접 확정한 뒤 Repeater 초안을 만듭니다.

문서의 메서드와 관측 메서드가 다르면 차이를 확인합니다. multipart는 실제 파일 요청을 사용합니다. 원본 캐시는 종류별 최대 100개, 패킷당 128 KiB로 제한됩니다. 근거가 제거되거나 너무 크면 새로 관측하거나 별도 보관하세요.

13 · 저장·조회 흐름 추적

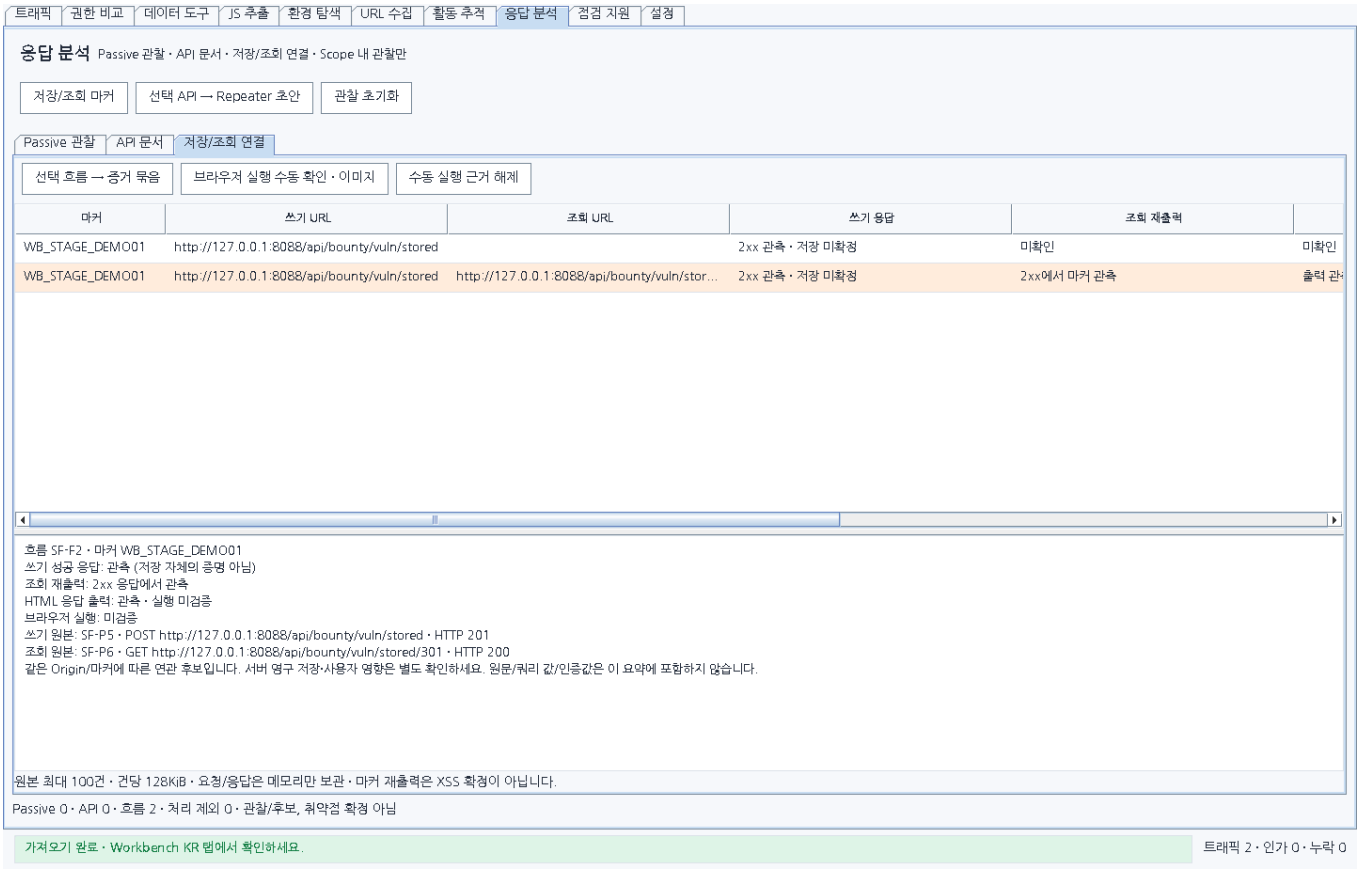


그림 10. 저장/조회 단계의 예시 메타데이터. 브라우저 실행은 확인하지 않았습니다.

1. 응답 분석 → 저장/조회 마커에서 WB_ 또는 PR_ 접두어의 고유 문자열을 등록합니다.

2. 댓글·게시글·업로드의 한 가지 입력에만 해당 마커를 넣고 쓰기를 실행합니다.

3. 목록, 상세, 파일 원문을 차례로 조회합니다.

4. 저장/조회 연결에서 쓰기 성공 여부·조회 URL·응답 맥락을 읽습니다.

5. '선택 흐름 → 증거 묶음'으로 원본 단계를 연결합니다.

6. HTML 2xx 후 실제 실행을 직접 확인했다면 '브라우저 실행 수동 확인 · 이미지'로 가린 PNG/JPEG를 연결합니다.

마커 재출력은 저장형 XSS 확정이 아닙니다. 쓰기·조회·HTML 출력·브라우저 실행을 분리해 읽으세요. 새 쓰기나 같은 URL의 새 조회 후에는 기존 수동 실행 근거를 다시 확인합니다. 이미지는 저장 시 해시를 재검증합니다.

14 · 페이로드 검사

페이로드 검사는 준비한 한 요청에서 특정 입력을 바꾸고 기준·공격·대조 응답을 비교합니다. 트래픽의 선택 요청을 '페이로드 검사'로 가져와 시작합니다.

1. 대상 URL과 세션이 유효한지 정상 요청으로 확인합니다.
2. 검사 위치와 프로필을 고르고 요청 예산을 작게 시작합니다.
3. 오류·반사·지연·콜백 등 판정 근거를 실제 응답과 대조합니다.
4. 변동이 큰 응답은 조건을 고정하고 다시 실행합니다.
5. 결과 → 증거 묶음으로 기준과 대조 요청을 함께 옮깁니다.

흔한 함정	확인할 사항
로그인 만료가 큰 차이로 표시됨	정상 기준 응답과 인증 상태
일시 지연을 취약점으로 오인	반복·대조군·서버 상태
출력 문자열만으로 XSS 확정	HTML 맥락과 브라우저 실행
상태코드만으로 파일 접근 성공	내용·길이·해시와 부분 응답
처리 제외를 성공으로 취급	시간·응답·취소·한도 상태

활성 검사는 명시적으로 실행합니다. 로컬 취약·수정 경로 쌍으로 먼저 도구의 판정 특성을 익히고, 검사 시도와 업무 완료를 분리하세요.

15 · 데이터 비교와 JWT

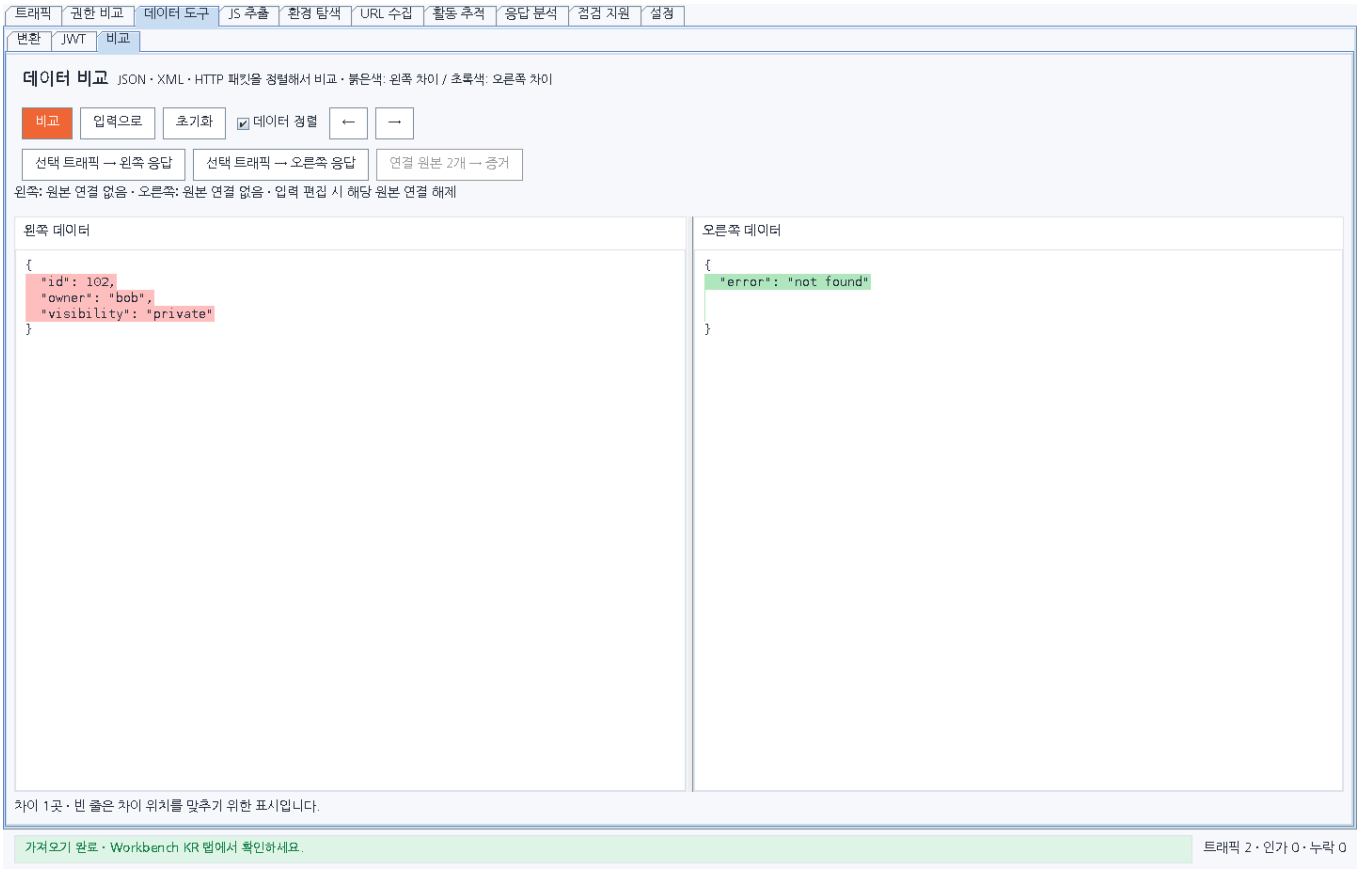


그림 11. 데이터 비교의 예시 차이. 붙여넣은 예시이므로 원본 연결은 없습니다.

데이터 비교에서는 같은 조건의 기준·변경 응답을 사용합니다. 차이는 현상이며 곧바로 취약점은 아닙니다. 원본 패킷을 연결해 두면 비교 결과를 증거로 옮길 때 입력 출처를 확인할 수 있습니다.

1. 각각의 기준 트래픽을 고르고 ‘선택 트래픽 → 왼쪽 응답’과 ‘선택 트래픽 → 오른쪽 응답’을 실행합니다.

2. ‘비교’ 후 ‘연결 원본 2개 → 증거’로 실제 패킷을 전달합니다.

3. 입력을 편집하면 해당 원본 연결이 해제됩니다. 붙여넣은 내용은 원본 증거가 아닙니다.

4. 표시 비교는 64 KiB/1,500줄로 제한되며 연결 원본은 요청·응답 합계 128 KiB 이하입니다.

JWT 디코딩은 서명 검증이 아닙니다. role 값이 보인다는 사실만으로 서버가 그 값을 신뢰한다고 결론 내리지 마세요. 변환 도구의 출력은 다음 도구에 넣기 전에 인코딩이 한 번 더 적용되지 않았는지 확인합니다.

16 · 여러 요청을 재현하기

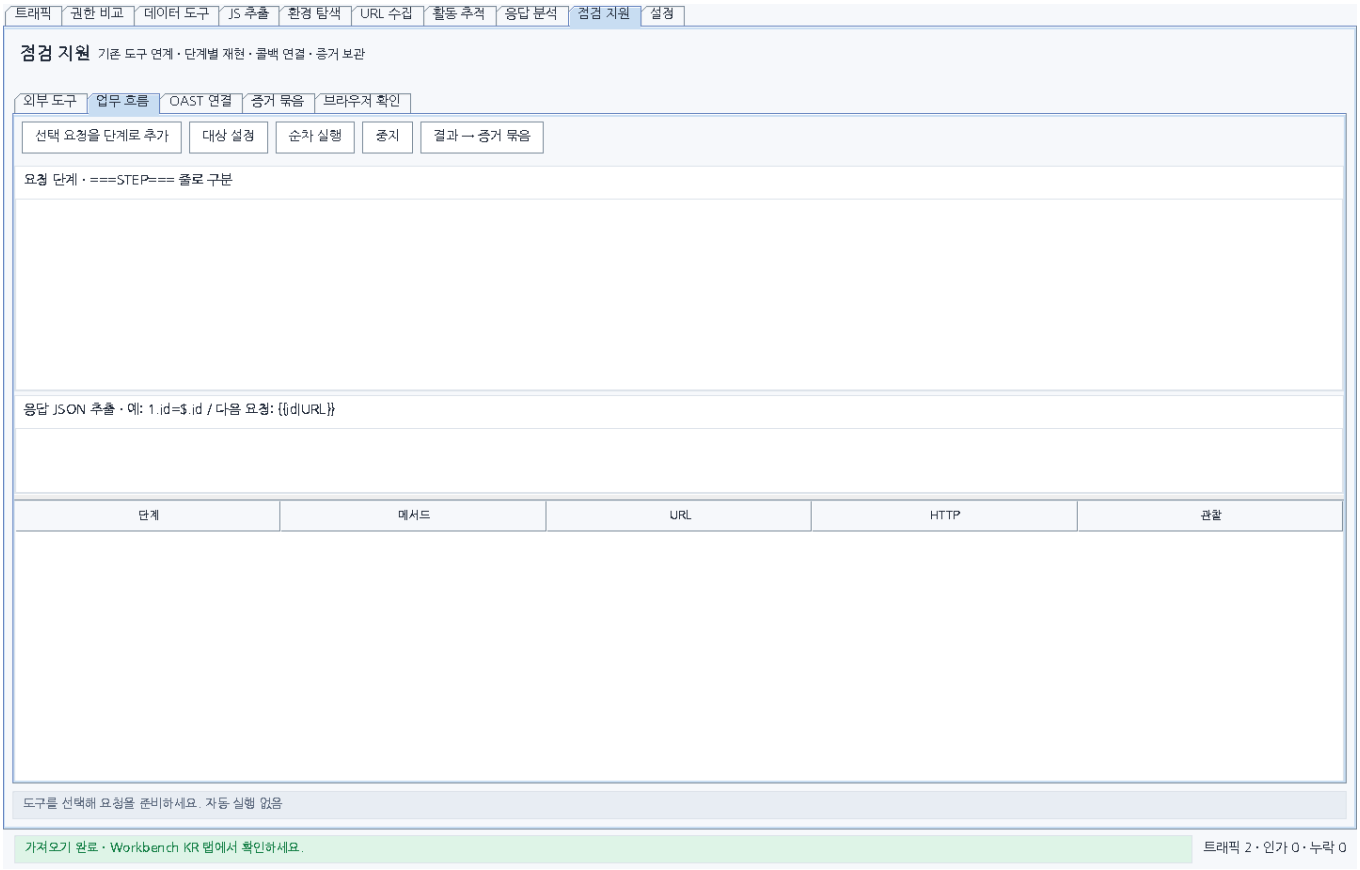


그림 12. 업무 흐름. 순차 요청과 응답 조건을 명시합니다.

1. 선택 요청을 단계로 추가하고 ===STEP=== 줄로 요청을 구분합니다.

2. 응답 JSON에서 다음 단계에 필요한 값을 추출합니다. 예: 1.id=$.id.

3. 다음 요청에 {{id|URL}}, {{id|JSON}}, {{id|RAW}} 중 맞는 인코딩을 사용합니다.

4. 대상 설정에서 Origin·쓰기 허용·기대 조건·요청 한도를 확인합니다.

5. 순차 실행 후 모든 단계의 요청·응답·중단 이유를 확인합니다.

6. 결과 → 증거 묶음으로 연결합니다.

최대 8단계, 같은 Origin/SCOPE, 리다이렉트 없이 실행합니다. 기대 조건 실패나 변수 추출 실패는 후속 단계 중단 근거입니다. 잘못된 이전 응답을 사용해 이후 작업을 계속하지 않도록 성공 조건을 구체적으로 정하세요.

17 · 제출 가능한 증거 묶음

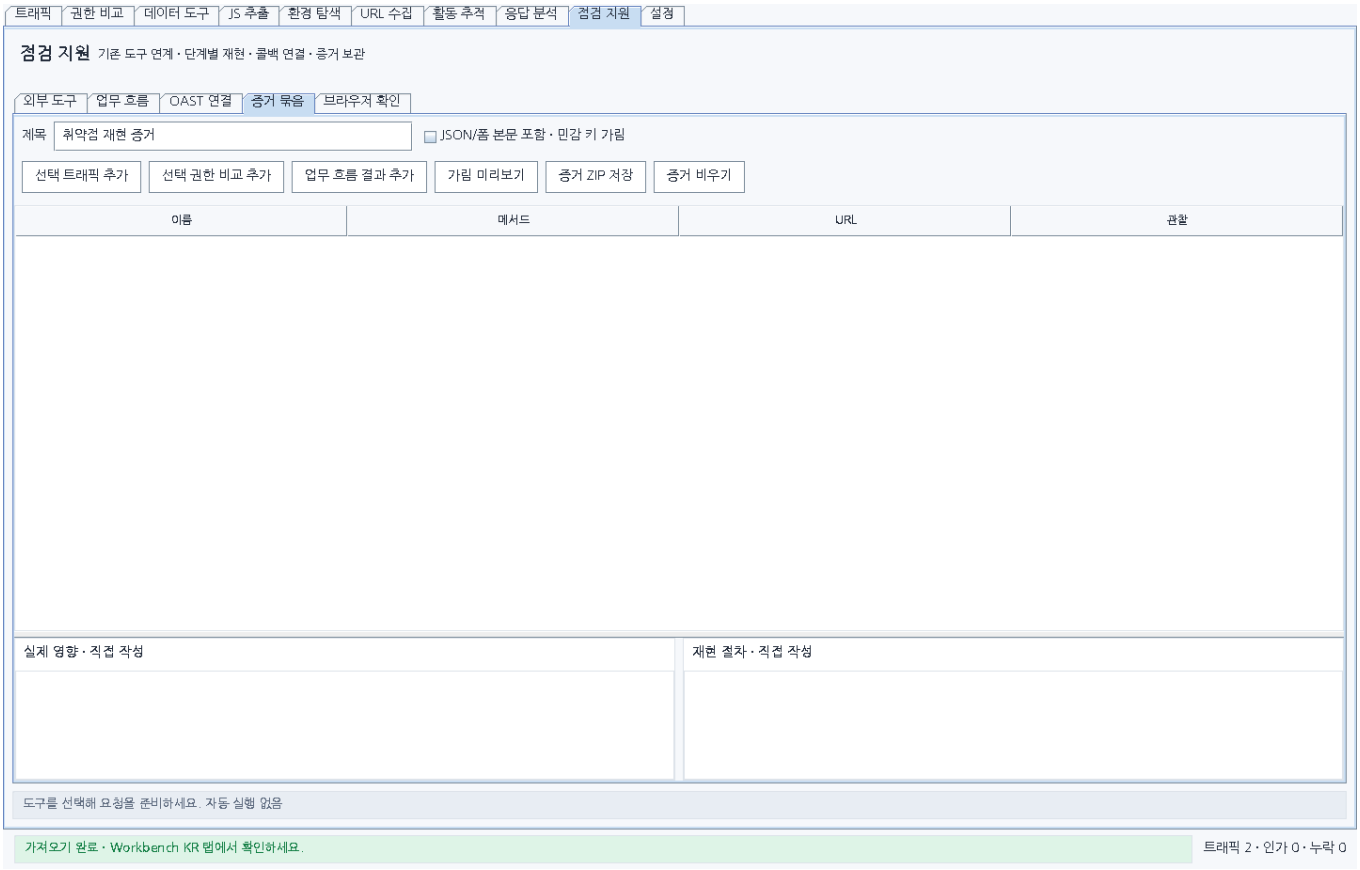


그림 13. 증거 묶음. 실제 영향과 재현 절차는 진단자가 작성합니다.

1. 필요한 트래픽·권한 비교·업무 흐름·페이로드·연결 원본을 추가합니다.

2. 제목에 대상 기능과 영향 하나를 적고 계정·선행 조건을 기록합니다.

3. JSON/폼 본문 포함 여부를 고른 뒤 ‘가림 미리보기’에서 저장될 민감 키·인증·쿼리 값 가림을 확인합니다.

4. 브라우저 근거가 있으면 개인정보를 가린 PNG/JPEG를 첨부합니다.

5. 증거 ZIP 저장 후 파일이 실제로 생성되었는지 확인합니다.

한 묶음은 요청 32개와 이미지 1장까지입니다. 다른 이미지 근거를 추가하려면 기존 증거를 저장하고 비운 뒤 새 묶음을 만듭니다. 최소 재현과 정상 대조를 포함하세요. 가려진 ZIP만으로 인증 재현이 완전히 가능하지 않으며 원본은 승인된 로컬 환경에서 별도로 관리합니다. 파일 해시는 진단 결론의 정확성을 보증하지 않습니다.

18 · OAST와 외부 도구 연결

Workbench는 Repeater·브라우저·외부 분석 도구로 넘기는 연결 지점을 제공합니다. 같은 기능을 중복 실행하기보다 각 도구의 근거를 점검 이력에 모읍니다.

작업	시작 위치	확인할 한계
외부 파라미터 결과 정리	점검 지원 → 외부 도구	입력 이름만 가져오며 값은 가져오지 않음
직접 요청 수정·재전송	선택 요청 → Repeater	전달은 전송이나 완료가 아님
콜백 ID 연결	점검 지원 → OAST 연결	Pro 서비스·외부 환경 필요
외부 OAST 결과 가져오기	ID·종류·시간·METHOD·URL 입력	같은 요청·같은 ID인지 검토
브라우저 근거	점검 지원 → 브라우저 확인	DOM·실행·출처는 직접 확인

콜백 주소 발급만으로 대상 요청을 자동 전송하지 않습니다. DNS 또는 HTTP 콜백은 외부 상호작용 관찰이며 SSRF·RCE 같은 영향은 별도로 입증해야 합니다.

현재 가이드의 UI 미리보기와 loopback HTTP 검증은 실제 Pro Collaborator, 외부 BApp, 실제 브라우저 실행을 대신하지 않습니다. 해당 기능을 사용할 때는 도구 버전과 실제 실행 결과를 별도로 남기세요.

19 · 완료와 재검토

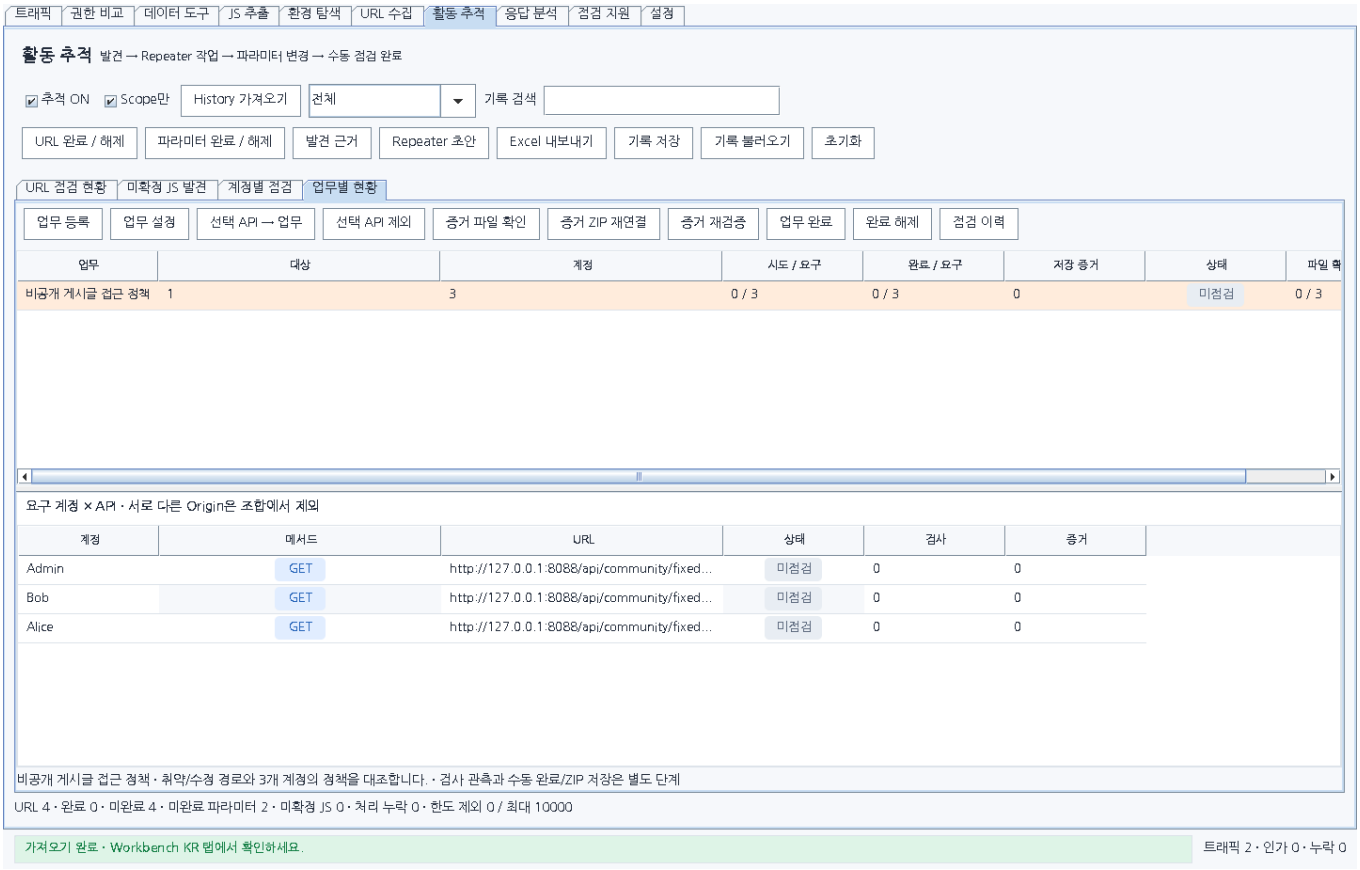


그림 14. 업무별 현황. 요구 조합과 파일 확인 조합을 함께 봅니다.

1. 각 계정에서 요구 API의 입력·응답·권한을 수동 검토합니다.

2. 선택한 입력 완료 조건과 증거 조건을 충족합니다.

3. ‘증거 재검증’으로 현재 파일의 삭제·변조를 확인합니다.

4. ‘업무 완료’를 명시적으로 누릅니다. 계정 재완료만으로 업무가 자동 마감되지는 않습니다.

파일을 이동했으면 ‘증거 ZIP 재연결’로 같은 해시의 파일을 선택합니다. JSON을 불러올 때 파일 경로·인증 연결·중요 입력 기준 해시는 복원하지 않습니다. 엄격 증거 조건의 업무는 파일 재연결 전 재검토가 필요합니다.

역할·조직·중요 입력·대상이 바뀌면 과거 증거의 적절성을 다시 확인하세요. 파일 상태는 마지막 수동 확인 결과이며 실시간 파일 감시가 아닙니다.

20 · 보고서 작성 예시

보고서는 재현 가능한 사실, 확인한 영향, 검증하지 않은 추정을 구분합니다. '취약'이라는 라벨보다 요청과 응답의 관계가 중요합니다.

항목	작성 예
제목	일반 회원이 다른 회원의 비공개 게시글을 조회 가능
선행 조건	Bob 소유 private 글 존재, Alice 일반 세션, 로컬 취약 모드
재현	Bob 정상 조회 → Alice로 같은 대상 조회 → fixed 경로 대조
기대	소유자 또는 관리자만 내용 열람
실제	Alice 응답에 Bob의 비공개 내용 반환
영향	타 회원의 비공개 정보 노출
증거	계정별 요청·응답, 대상·시각, 저장 ZIP 해시
제외·한계	실제 서비스 영향·운영 DB·브라우저 실행은 별도 확인

위 표는 작성 형식 예시입니다. 이번 실행 결과로 제출하려면 실제 응답·계정 연결·정상 대조를 다시 확인하고 현재 증거를 첨부해야 합니다.

개선 후에는 같은 조건으로 다시 검사하고, 취약 경로의 학습 동작과 수정 경로의 기대 정책이 모두 유지되는지 확인하세요. 결과가 달라진 경우 초기 상태·데이터·세션 차이를 먼저 기록합니다.

21 · 개발·검증·다음 업데이트

저장소 루트에서 Python 3.10 이상과 JDK 17 이상을 사용합니다. 공식 빌드는 dev.py → build_all.py이며 이전 버전이 적힌 Maven POM은 확장 배포 경로가 아닙니다.

```
python dev.py doctor
python dev.py check
python dev.py release
python tools/package_downloads.py --verify
python tools/build_guide.py
```

확인할 기록	의미
docs/VERIFICATION_0.23.0.json	이 버전에서 실제 실행한 검사와 한계
해당 PR의 Actions	원격 커밋에 대한 자동 빌드·회귀·패키지 검증
docs/GUIDE_0.23.0_KR.md	현재 가이드의 편집 가능한 원문
tools/GuidePreview.java	운영 UI를 예시 데이터로 렌더한 그림 생성기
downloads/	버전별 불변 JAR·소스·Docker·안내서
history/, setup/, release/	이전 환경과 이전 버전의 기록

새 배포는 기존 버전 폴더를 덮어쓰지 않습니다. 소스를 수정한 뒤 빌드·회귀·HTTP 검사를 통과시키고 다운로드를 함께 갱신합니다. 과거 Burp 화면 검사나 Docker 관련 문서를 현재 버전 검증으로 합산하지 않습니다.

실제 Burp에서의 장시간 수집·GUI, 전체 Docker/Oracle/Nginx, Pro 서비스와 외부 BApp은 실제 실행한 기록이 있을 때만 완료로 표시하세요. 이 안내서는 기능 사용법이며 모든 환경과 모든 취약점의 검증 완료를 보증하지 않습니다.